

Cyber Threat Intelligence

Executive Briefing

Report Date: July 11, 2026

Generated: 2026-07-11 20:37 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
3	9	8	0	20

2. Executive Summary

As of July 11, 2026, security assessments have analyzed 20 total vulnerabilities, categorized as 3 Critical, 9 High, 8 Medium, and 0 Low. The current organizational risk posture is classified as critical, primarily driven by exploitable vulnerabilities that facilitate unauthorized remote code execution and unauthenticated system manipulation. CVE-2026-52778, Remote Code Execution via Unsafe Eval, represents the highest priority threat due to the potential for full system compromise through the exploitation of mathematical expression processing components. Immediate response requires the implementation of emergency patching protocols and restricted network access for the affected YesWiki modules to mitigate identified attack vectors. All relevant systems must be brought into compliance with established security baselines within the mandated remediation windows.

3. Critical Action List

- CVE-2026-52778: Immediately disable the Formula Calculator component and deploy vendor-supplied hotfix within 24 hours.
- CVE-2026-52766: Restrict access to the {{erasespamedcomments}} action via web application firewall rules within 24 hours while awaiting patch validation.
- CVE-2026-52775: Audit and implement comprehensive input sanitization for the ReactionManager component within 48 hours to neutralize SQL injection vectors.
- CVE-2026-52771: Apply sanitization protocols to the ApiController::deletePage method within 48 hours to prevent second-order SQL injection.
- CVE-2026-52769: Implement egress filtering and update ActivityPub signature verification logic within 48 hours to remediate the SSRF vulnerability.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-52778	Remote Code Execution via Unsafe ...	9.8	Critical	88/100	CWE-94
CVE-2026-52766	Unauthenticated Arbitrary Page De...	9.1	Critical	82/100	CWE-276
CVE-2026-52775	Authenticated SQL Injection in Re...	8.8	High	79/100	CWE-89
CVE-2026-52771	Second-Order SQL Injection in Pag...	8.3	High	75/100	CWE-89
CVE-2026-52769	SSRF in ActivityPub Key Retrieval	8.3	High	75/100	CWE-918
CVE-2026-52767	Signature Verification Bypass in ...	8.2	High	74/100	CWE-347
CVE-2026-52777	Authenticated PHP Object Injectio...	8.8	High	73/100	CWE-352
CVE-2026-53932	OS Command Injection in Database ...	8.0	High	72/100	CWE-77
CVE-2026-52770	SQL Injection in Bazar Entry List...	7.5	High	68/100	CWE-89
CVE-2026-53727	SSRF and Local File Disclosure in...	7.5	High	68/100	CWE-918
CVE-2026-52762	RCE via Template Injection in Baz...	7.2	High	65/100	CWE-1336
CVE-2026-53602	Lack of Durable Revocation in Neb...	9.1	Critical	61/100	CWE-613
CVE-2026-53637	Unauthorized Modification of Comp...	6.5	Medium	59/100	CWE-672
CVE-2026-52763	SQL Injection in Recent Changes	6.5	Medium	59/100	CWE-89
CVE-2026-53769	Upload Authorization Bypass in Avo	6.5	Medium	59/100	CWE-862
CVE-2026-52774	Reflected XSS in Bazar Widget	6.1	Medium	55/100	CWE-80
CVE-2026-52773	Reflected XSS in Page Revision Ha...	6.1	Medium	55/100	CWE-80
CVE-2026-52772	Stored XSS in Bazar Form Templates	5.5	Medium	50/100	CWE-79
CVE-2026-53760	CSRF in Admidio Plugin Management	5.2	Medium	47/100	CWE-352
CVE-2026-53638	Channel Restriction Bypass in Sho...	4.3	Medium	39/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-52778

Finding: Remote Code Execution via Unsafe Eval

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-94

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki's Formula Calculator component utilizes an unsafe eval() function for mathematical expression processing. The lack of input sanitization or sandboxing enables the execution of arbitrary PHP code provided within the calculator input

field. Unauthenticated remote attackers can leverage this vulnerability to gain full remote code execution, resulting in total system compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the YesWiki formula calculator input field. The attacker inputs a payload containing PHP system execution commands disguised as a mathematical expression. The application passes this string directly into the internal eval() function without validation. This results in the server executing the payload, granting the attacker arbitrary code execution privileges.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52778>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52778>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52778>

CVE-2026-52766

Finding: Unauthenticated Arbitrary Page Deletion

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-276

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1485, T1490

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

YesWiki allows unauthenticated users to invoke the `{{erasespamedcomments}}` action, which results in the deletion of site content. The lack of an authentication check in this specific action allows any remote user to trigger the deletion logic. This vulnerability poses a critical risk to the availability and integrity of the site's data.

Proof of Concept (PoC):

An unauthenticated attacker sends a request to a YesWiki page containing the `{{erasespamedcomments}}` markup. The application parses the markup and executes the associated action without checking if the user is authorized. The execution logic removes the intended content from the database. This results in permanent data loss and service disruption.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52766>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52766>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52766>

CVE-2026-52775

Finding: Authenticated SQL Injection in ReactionManager

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The ReactionManager component in YesWiki is vulnerable to SQL injection due to improper sanitization of inputs within database queries. An authenticated attacker can manipulate SQL query parameters to gain unauthorized access to or modify backend database contents. This impacts the confidentiality and integrity of the system by allowing arbitrary database operations.

Proof of Concept (PoC):

An authenticated attacker intercepts a request processed by the ReactionManager. The attacker injects malicious SQL statements into the parameter being sent to the backend database. The application concatenates this input directly into the query without parameterized execution. This results in the database executing the injected commands, exposing sensitive data to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52775>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52775>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52775>

CVE-2026-52771

Finding: Second-Order SQL Injection in Page Deletion

CVSS v3.1 Score: 8.3 | Severity: High | Urgency Score: 75/100 | CWE: CWE-89

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The `ApiController::deletePage` method in YesWiki exhibits a second-order SQL injection vulnerability through the handling of page tags. The application stores unsanitized user-supplied tags, which are subsequently processed in a vulnerable database query during the page deletion operation. This allows an attacker to execute arbitrary SQL commands when interacting with the API.

Proof of Concept (PoC):

An attacker saves a page with a tag containing a malicious SQL injection payload. Later, the attacker triggers the page deletion API, which retrieves and uses that tag in an unsanitized SQL query. The backend database executes the payload contained within the tag. This results in potential unauthorized data exfiltration or system modification.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52771>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52771>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52771>

CVE-2026-52769

Finding: SSRF in ActivityPub Key Retrieval

CVSS v3.1 Score: 8.3 | Severity: High | Urgency Score: 75/100 | CWE: CWE-918

Score Provenance: Unverified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

YesWiki contains an unauthenticated Server-Side Request Forgery vulnerability within the ActivityPub signature verification process, triggered by the `Signature.keyId` parameter. The application performs outbound requests to user-supplied URLs to fetch keys, without validating the destination host. This allows an attacker to perform internal network scanning and access sensitive metadata from the application server.

Proof of Concept (PoC):

An unauthenticated attacker sends an ActivityPub request to YesWiki, providing a local network URL in the `Signature.keyId` field. The server attempts to fetch the signing key from the provided URL, facilitating interaction with internal services. The server then returns the result of the fetch to the attacker. This results in unauthorized access to sensitive internal resources.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52769>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52769>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52769>

CVE-2026-52767

Finding: Signature Verification Bypass in ActivityPub

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-347

Score Provenance: Unverified

MITRE ATT&CK: T1558

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

YesWiki's ActivityPub signature verification implementation is vulnerable to a logic error where the result of `!openssl\_verify()` accepts `int(-1)` as a valid authentication state. This allows an unauthenticated attacker to bypass cryptographic signature checks by providing an invalid signature that triggers the error code. The flaw enables the spoofing of ActivityPub messages, compromising the integrity of the federated content.

Proof of Concept (PoC):

An unauthenticated attacker sends an ActivityPub message to the instance, setting the signature to an invalid value that causes the OpenSSL function to return -1. The application checks the result using a logic that interprets -1 as a successful verification due to improper strict equality checking. This results in the server accepting the forged message as authentic.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52767>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52767>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52767>

CVE-2026-52777**Finding: Authenticated PHP Object Injection in Bazar**

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 73/100 | CWE: CWE-352

Score Provenance: Unverified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The BazarImportAction in YesWiki improperly utilizes the PHP unserialize() function on user-supplied input. This flaw allows an authenticated user to inject malicious serialized objects, potentially leading to arbitrary code execution or object state manipulation. The resulting vulnerability poses a severe threat to the confidentiality and integrity of the application server.

Proof of Concept (PoC):

An authenticated user with low privileges targets the BazarImportAction endpoint. The attacker crafts a malicious serialized PHP object payload designed to trigger a gadget chain. The application calls unserialize() on the input without proper validation or filtering. This results in the instantiation of arbitrary objects, which allows for remote code execution or state corruption.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52777>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52777>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52777>

CVE-2026-53932**Finding: OS Command Injection in Database Restore**

CVSS v3.1 Score: 8.0 | Severity: High | Urgency Score: 72/100 | CWE: CWE-77

Score Provenance: Unverified

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
---------------	---------

Attack Complexity	Low
-------------------	-----

Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The `laravel-backup-restore` package is susceptible to OS command injection during the database restore process. The vulnerability is caused by improperly sanitized user inputs that are directly concatenated into system commands used to invoke database binaries. An attacker can supply crafted input to achieve remote code execution on the underlying host.

Proof of Concept (PoC):

An authenticated user with administrative rights initiates a backup restoration by passing a crafted argument to the restore command. The underlying package constructs a shell command using this argument without sufficient filtering. The operating system interprets the malicious input as a valid command. This results in remote code execution with the permissions of the application user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53932>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53932>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53932>

CVE-2026-52770

Finding: SQL Injection in Bazar Entry Listing

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-89

Score Provenance: Unverified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Public Bazar entry-listing APIs in YesWiki are susceptible to SQL injection via the `query` and `queries` numeric filter parameters. The application lacks proper input validation for these numeric inputs, permitting attackers to inject malicious SQL syntax into the query execution. This allows unauthorized access to backend database contents.

Proof of Concept (PoC):

An unauthenticated attacker sends a GET request to the Bazar entry-listing API, modifying the `query` parameter to include an SQL injection payload. The server processes this parameter as part of a database query without adequate sanitization. This results in the database executing the malicious query and returning unauthorized information to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52770>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52770>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52770>

CVE-2026-53727

Finding: SSRF and Local File Disclosure in CSS Parser

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-918

Score Provenance: Unverified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Ruby CSS Parser's ``CssParser::Parser#read_remote_file`` method is vulnerable to Server-Side Request Forgery and Local File Disclosure. The method fails to restrict URI schemes, allowing an attacker to specify ``file://`` or internal service URLs. This permits the attacker to read arbitrary files from the server or interact with internal networked services.

Proof of Concept (PoC):

An attacker provides a malicious CSS source URL using the ``file:///etc/passwd`` scheme to an application utilizing the Ruby CSS Parser. The ``read_remote_file`` method processes the URI without validating the scheme or path constraints. The parser reads the contents of the local file and includes it in the CSS output. This results in the exposure of sensitive server files to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53727>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53727>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53727>**CVE-2026-52762****Finding: RCE via Template Injection in Bazar****CVSS v3.1 Score: 7.2 | Severity: High | Urgency Score: 65/100 | CWE: CWE-1336**

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki allows administrative users to perform Server-Side Template Injection via Bazar semantic templates, leading to Remote Code Execution. The vulnerability stems from insecure handling of user-controllable template directives that resolve to underlying system commands or application code execution. This allows an admin account to compromise the entire server environment.

Proof of Concept (PoC):

An authenticated administrator submits a malicious semantic template containing template injection syntax to the Bazar configuration section. The template engine evaluates this input during page rendering without sufficient sanitization. The

malicious template triggers a server-side execution of arbitrary code. This results in full administrative control over the underlying operating system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52762>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52762>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52762>

CVE-2026-53602

Finding: Lack of Durable Revocation in Nebula-Mesh

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 61/100 | CWE: CWE-613

Score Provenance: Unverified
MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

The Nebula-Mesh host revocation mechanism is not durable, allowing offboarded hosts to potentially regain valid certificates. The failure occurs because the revocation state is cached improperly, and certificate re-enrollment logic does not correctly verify the revocation status against the source-of-truth. This enables a revoked host to maintain connectivity, violating access control policies.

Proof of Concept (PoC):

A revoked host attempts to request a new certificate using stale credentials during a renewal window. The Nebula-Mesh server verifies the certificate request against a flawed cache rather than the definitive blacklist. The server issues a valid certificate despite the host's revoked status. This results in the host maintaining unauthorized access to the network mesh.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53602>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53602>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53602>

CVE-2026-53637

Finding: Unauthorized Modification of Completed Orders

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-672

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	High	Availability Impact	None

Description:

The Sylius Cart FormComponent permits the modification or deletion of orders that have already reached a completed status. The root cause is the absence of an order state validation check before invoking state-mutating methods on completed order entities. This flaw allows an authenticated attacker to alter finalized transaction records, violating business logic and data integrity.

Proof of Concept (PoC):

An authenticated customer accesses the order history via the Cart FormComponent. The attacker identifies a completed order ID and sends a request to the update handler to modify line items or delete the order entity. The application processes the request because it fails to verify that the order state is still mutable. This results in the successful unauthorized modification of a legally completed transaction.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53637>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53637>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53637>

CVE-2026-52763**Finding: SQL Injection in Recent Changes**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-89

Score Provenance: Unverified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The `recentchanges` action in YesWiki improperly sanitizes the `period` argument when generating SQL queries for the database. This enables an SQL injection vulnerability where an attacker can influence the database query. This vulnerability provides a pathway for unauthorized reading of site data.

Proof of Concept (PoC):

An unauthenticated attacker requests the `recentchanges` page with a manipulated `period` argument containing SQL keywords. The application injects this input directly into the query building logic. The database executes the resulting malicious query, which leads to unauthorized data retrieval. This results in the leakage of site activity records.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52763>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52763>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52763>

CVE-2026-53769**Finding: Upload Authorization Bypass in Avo**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The direct attachment upload endpoint in Avo fails to verify upload authorization, effectively bypassing field-level upload policy. This vulnerability occurs due to the lack of access control checks on the storage request handler. An attacker can upload files to unauthorized storage locations, impacting the integrity of the filesystem.

Proof of Concept (PoC):

An authenticated user with low privileges sends a POST request to the Avo attachment upload endpoint. The request provides a file intended for a field or location the user is not authorized to modify. The server processes the upload without checking the user's permissions or the field policy. This results in the unauthorized placement of files on the server.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53769>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53769>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53769>**CVE-2026-52774****Finding: Reflected XSS in Bazar Widget****CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-80**

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1189

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

The Bazar widget in YesWiki fails to properly escape the `id` parameter used within HTML attributes, leading to a Reflected Cross-Site Scripting vulnerability. An attacker can craft a malicious URL containing JavaScript payloads that are executed in the context of the user's browser. This enables session hijacking, credential theft, or unauthorized actions on behalf of the victim.

Proof of Concept (PoC):

An attacker creates a malicious link pointing to the YesWiki Bazar widget with the `id` parameter set to a script-based payload. A victim clicks the link, and their browser sends the request to the application. The application reflects the unsanitized `id` parameter back into the HTML output. This results in the victim's browser executing the injected script.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52774>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52774>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52774>

CVE-2026-52773

Finding: Reflected XSS in Page Revision Handler

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-80

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1189

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

The `handlers/page/show.php` file in YesWiki fails to escape the `time` parameter of archived revisions, resulting in a Reflected Cross-Site Scripting vulnerability. Remote attackers can inject arbitrary client-side scripts that execute when a victim visits a specifically crafted URL. This facilitates the potential theft of session tokens and further malicious interaction with the web application.

Proof of Concept (PoC):

An attacker constructs a URL targeting the page revision handler with a JavaScript payload injected into the `time` parameter. The attacker convinces a user to click this link. The server receives the request and renders the unsanitized `time` parameter directly into the page source. This results in the execution of the attacker's JavaScript within the victim's active session.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52773>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52773>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52773>

CVE-2026-52772

Finding: Stored XSS in Bazar Form Templates

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 50/100 | CWE: CWE-79

Score Provenance: Unverified

MITRE ATT&CK: T1189

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	High
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Bazar form-field templates in YesWiki fail to properly encode `field.label` and `field.hint` values when using the `raw('html')` filter. This deficiency creates a Stored Cross-Site Scripting vulnerability where malicious scripts are saved to the database. These scripts subsequently execute in the browser of any user viewing the affected Bazar form.

Proof of Concept (PoC):

An attacker with authorized access to modify Bazar forms inserts a script tag into the `field.label` property. The application saves this malicious content to the database without filtering. When a user visits the form page, the application renders the stored script inside the page DOM. This results in the automatic execution of the attacker's script in the user's browser session.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52772>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52772>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52772>

CVE-2026-53760

Finding: CSRF in Admidio Plugin Management

CVSS v3.1 Score: 5.2 | Severity: Medium | Urgency Score: 47/100 | CWE: CWE-352

Score Provenance: Unverified

MITRE ATT&CK: T1521

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:R/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	Low

Description:

Admidio is vulnerable to Cross-Site Request Forgery via unprotected GET requests used for plugin installation, uninstallation, and updates. The lack of anti-CSRF tokens in these administrative actions allows an attacker to trigger state changes on behalf of an authenticated administrator. This could lead to malicious plugin installation and further system compromise.

Proof of Concept (PoC):

An attacker creates a malicious webpage that includes hidden GET requests to the Admidio plugin management dashboard. The attacker lures an authenticated administrator into visiting this site. The browser automatically sends the requests to the Admidio instance. This results in unauthorized plugins being installed or removed, compromising the site's configuration.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53760>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53760>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53760>

CVE-2026-53638

Finding: Channel Restriction Bypass in Shop API

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-863

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	Low

Confidentiality Impact	None
Availability Impact	None

Description:

The Sylius shop account orders API endpoint fails to enforce channel-based payment method restrictions during order processing. The root cause is a deficiency in the authorization logic which neglects to validate if the selected payment method is associated with the requested channel. This allows an authenticated user to perform unauthorized transactions, compromising integrity and service logic.

Proof of Concept (PoC):

An authenticated user logs into the shop account. The user sends a PATCH request to the orders API endpoint with a payment method ID that is restricted from the current channel. The server processes the payment assignment without verifying channel compliance. This results in the order being successfully processed despite business policy restrictions.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53638>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53638>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53638>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>